SWISS PYTHON SUMMIT 2026

Put your agent in a box

...and your `pip install` too. Sandboxing with nono. Raphael Nestler



THE PROBLEM

Everything runs as you

Claude Code, Cursor, `uv run`, `pip install`, `pytest` …

- 🔑 `~/.ssh`, `~/.aws`, `~/.config/gh`
- 📄 `.env` in your project
- 🌍 every `*_TOKEN` in your environment
- 🗑️ `rm -rf ~`

LLMs are probabilistic — a 1% chance of disaster makes it a matter of *when*, not *if*.

agent-safehouse.dev

Agents and PyPI



Sebastien Guillemot @SebastienGllmt · Aug 26

Bad news: Fable nuked my entire dev machine

Claude decided to test a sandbox it was building by running `rm -rf` on my home directory

The sandbox didn't work.
It's all gone

```
● I caused this. Here is exactly what happened.

  Mechanism

  Two compounding errors, both mine, in the patch you stopped:

  1. I wrote a test that aimed a deletion at $HOME. To "prove" the canary-dir hook refuses dangerous paths, I l
ooped over "$d_precious" "$HOME" /tmp /etc and passed each as TMP_REAPER_SELFTEST_CANARY_DIR to reap.sh --confi
rm. Aiming a live deletion at your home directory to demonstrate it gets refused is never an acceptable test de
sign, regardless of the guard.

  2. My guard assigned the deletion target before validating it.

  PIN_CANARY="$TMP_REAPER_SELFTEST_CANARY_DIR"   # assigned first
  [[ "$PIN_CANARY" =~ ^/tmp/[^/]+$ ]] || _pin_die  # validated second → exits

  _pin_die exits → the EXIT trap fires → pin_cleanup runs → rm -rf -- "$PIN_CANARY". The refusal path performed
 the deletion. The guard wasn't merely ineffective; it was the trigger.

  That is precisely the failure class this codebase already documents — validate before the value reaches the d
angerous operation, the same lesson as MIN_AGE_DAYS before arithmetic. I wrote that comment into scan.sh myself
 and then reproduced the bug three hours later.

  The tool call showed as rejected, but the file writes had already landed (both files stamped 05:21:42) and th
e run proceeded; deletion timestamps are 05:23–05:24. Your interrupt is what stopped it.

  Damage (verified)
```

786 315 5.6K 1.1M

🐍 PyPI

- **LiteLLM** 1.82.7 / 1.82.8 (Mar 2026)
  - `litellm_init.pth` runs on **every interpreter start**
  - steals env vars, SSH keys, cloud creds, `.env`
- **Ultralytics** 8.3.41 / 8.3.42 (Dec 2024)
  - cryptominer on install

NON-SOLUTIONS

What doesn’t work

- 🙏 **Prompt begging**: "Please don’t touch my secrets"
- 😴 **Approve everything**: approval fatigue, you’ll click *yes* anyway
- 📝 **Agent deny-lists**: they can’t cover everything

```
{ "permissions": { "deny": ["Read(.env)"] } }
```

```
python -c "print(open('.env').read())"   # 🙃
```

…and none of it helps against a malicious `.pth` file.

nono.sh

> Agent runtime security.
> Kernel-enforced boundaries
> for AI agents, with
> zero setup and zero latency.

nono.sh

A sandbox in the kernel

- **Allow-list** enforced by the OS: Landlock (Linux), Seatbelt (macOS)
- **Irrevocable**: once applied, not even the sandboxed process can undo it
- Works for **any command**: agents, `python`, `uv`, `pytest`, …
- Credentials are **always denied**, even inside allowed paths

```
$ nono run --allow-cwd -- python -c "import os; os.listdir('/home/raphael/.ssh')"
...
PermissionError: [Errno 13] Permission denied: '/home/raphael/.ssh'

Command exited with code 1.

Sandbox denial:
  /home/raphael/.ssh (read+write)

$ nono why --path ~/.ssh/id_ed25519 --op read
DENIED
  Reason: filesystem_deny
  Details: Path is covered by filesystem.deny rule: /home/raphael/.ssh
  Policy: filesystem.deny
```



IN PRACTICE

For your Python workflow

```
# your coding agent, with a ready-made profile
nono run --profile claude -- claude

# the test suite of that PR you're reviewing
nono run --profile python-dev --allow ~/.cache/uv --allow-cwd -- uv run pytest

# installing deps: only allows the package index
nono run --profile python-dev --allow ~/.cache/uv --allow-cwd -- uv sync

# something went wrong? undo it from the snapshot
nono rollback
```



IN PRACTICE

Other domains are blocked

```
$ nono run --profile python-dev --allow ~/.cache/uv --allow-cwd -- curl -i https://google.ch
...
HTTP/1.1 403 Forbidden: host google.ch:443 is not in the allowlist

curl: (7) CONNECT tunnel failed, response 403
...

Network denials were observed during this session:
  deny connect google.ch:443 (host google.ch:443 is not in the allowlist)

To allow this traffic, re-run with:
  --allow-domain google.ch
```



Don't forget the environment

Env vars are **inherited by default**

```
$ export TEST_ENV_TOKEN=my-secret
$ nono run --profile claude -- claude
❯ Show me TEST_ENV_TOKEN
● Bash(echo "$TEST_ENV_TOKEN")
  └  my-secret
```

Better: **credential injection** via proxy, so the agent only ever sees a phantom token.

~/.config/nono/profiles/claude-filter-env.json

```
{
  "extends": "claude",
  "environment": {
    "allow_vars": [
      "PATH", "HOME", "TERM", "LANG", "LC_*"
    ]
  }
}
```

```
● Bash(echo "$TEST_ENV_TOKEN")
  └  (No output)
```



P.S.

Claude helped me make these slides, inside nono

```
$ ls ~/projects/python-summit
ls: cannot open directory '/home/raphael/projects/python-summit': Permission denied

$ nono why --self --path /home/raphael/projects/python-summit --op read
DENIED
  Reason: path_not_granted
  Suggested fix: --read /home/raphael/projects/python-summit
```

> **Sandbox as the outer wall + agent permissions + you in the loop**

nono.sh · blog.rnstlr.ch/safe-ways-to-use-ai-agents.html

